

Hiveforce Labs

THREAT ADVISORY

 VULNERABILITY REPORT

Microsoft addresses actively exploited zero-day and numerous critical flaws

Date of Publication

December 14, 2022

Admiralty Code

A1

TA Number

TA2022297

Summary

First Seen: December 13, 2022

Affected Product: Microsoft Windows and Windows Server

Impact: Jeopardizing security constraints to attain Remote Code Execution and Privilege Escalation.

CVE

CVE	NAME	PATCH
CVE-2022-44698	Windows SmartScreen Security Feature Bypass Vulnerability	
CVE-2022-44710	DirectX Graphics Kernel Elevation of Privilege Vulnerability	
CVE-2022-44690	Microsoft SharePoint Server Remote Code Execution Vulnerability	
CVE-2022-44693	Microsoft SharePoint Server Remote Code Execution Vulnerability	
CVE-2022-41089	.NET Framework Remote Code Execution Vulnerability	
CVE-2022-41076	PowerShell Remote Code Execution Vulnerability	
CVE-2022-44678	Windows Print Spooler Elevation of Privilege Vulnerability	

CVE	NAME	PATCH
CVE-2022-44681	Windows Print Spooler Elevation of Privilege Vulnerability	
CVE-2022-44713	Microsoft Outlook for Mac Spoofing Vulnerability	
CVE-2022-41127	Microsoft Dynamics NAV and Microsoft Dynamics 365 Business Central (On Premises) Remote Code Execution Vulnerability	
CVE-2022-44670	Windows Secure Socket Tunneling Protocol (SSTP) Remote Code Execution Vulnerability	
CVE-2022-44683	Windows Kernel Elevation of Privilege Vulnerability	

Vulnerability Details

#1

Patch Tuesday for December tackles two zero-day vulnerabilities, one of which is being actively exploited (CVE-2022-44698) and another that was publicly disclosed at the time of release (CVE-2022-44710), along with the additional critical flaws that could result in Remote Code Execution, Elevation of Privilege (EoP), Security Feature Bypass, and Spoofing.

#2

The Windows operating system contains a security feature bypass vulnerability (CVE-2022-44698), which is classified as publicly disclosed and resulted from a Windows SmartScreen error. A remote attacker can circumvent MOTW safeguards and prevent SmartScreen from running a reputation check on the downloaded file.

#3

Microsoft is also emphasizing CVE-2022-44710, a privilege escalation flaw in the DirectX graphics kernel. The vulnerability exists because of a race situation in the DirectX Graphics Kernel. A local user can take advantage of the race to acquire unauthorized access to sensitive information and escalate system privileges.

#4

CVE-2022-44690 and CVE-2022-44693 are RCE vulnerabilities that impact Microsoft SharePoint Server. An authenticated attacker with Manage List permission on the SharePoint server could remotely execute code. The flaw exists owing to poor validation of user-supplied input in the Microsoft SharePoint Server.

#5

CVE-2022-44678 and CVE-2022-44681 are flaws in the Windows Print Spooler components that allow a local user to elevate system privileges. The weakness exists since the program fails to correctly enforce security constraints in the Windows Print Spooler, allowing security controls to be bypassed and privilege escalation to occur.

Vulnerability

CVE ID	AFFECTED PRODUCTS	AFFECTED CPE	CWE ID
CVE-2022-44698	Windows: 10 - 11 22H2 & Windows Server: 2016 - 2022 20H2	cpe:2.3:o:microsoft:windows:-:*:*:*:*:* cpe:2.3:o:microsoft:windows_server:-:*:*:*:*:*	CWE-254
CVE-2022-44710	Windows: 10 - 11 22H2	cpe:2.3:o:microsoft:windows:-:*:*:*:*:*	CWE-362
CVE-2022-44690	Microsoft SharePoint Server Subscription Edition: All versions, Microsoft SharePoint Foundation: 2013 Service Pack 1 & Microsoft SharePoint Enterprise Server: 2013 Service Pack 1 – 2016	cpe:2.3:a:microsoft:microsoft_sharepoint_server_subscription_edition:*:*:*:*:*:*	CWE-20
CVE-2022-44693		cpe:2.3:a:microsoft:microsoft_sharepoint_foundation:*:*:*:*:*:* cpe:2.3:a:microsoft:microsoft_sharepoint_enterprise_server:*:*:*:*:*:*	CWE-20
CVE-2022-41089	Microsoft .NET Core: 3.1, Microsoft .NET Framework: 2.0 - 4.8.1, Visual Studio: 2019 for Mac version 8.9 - 2022 version 17.4 & .NET: 6.0 - 7.0	cpe:2.3:a:microsoft:microsoft_.net_core:-:*:*:*:*:*	CWE-20
CVE-2022-41076	Windows: 7 - 11 22H2, Windows Server: 2008 – 2022 & PowerShell: 7.2 - 7.3	cpe:2.3:o:microsoft:windows:-:*:*:*:*:* cpe:2.3:o:microsoft:windows_server:-:*:*:*:*:*	CWE-20
CVE-2022-44678	Windows: 7 - 11 22H2 & Windows Server: 2008 – 2022	cpe:2.3:o:microsoft:windows:-:*:*:*:*:* cpe:2.3:o:microsoft:windows_server:-:*:*:*:*:*	CWE-264
CVE-2022-44681	Windows: 7 - 11 22H2, Windows Server: 2008 – 2022 & Microsoft Dynamics 365 Field Service (on-premises): All versions	cpe:2.3:o:microsoft:windows:-:*:*:*:*:* cpe:2.3:o:microsoft:windows_server:-:*:*:*:*:*	CWE-264

CVE ID	AFFECTED PRODUCTS	AFFECTED CPE	CWE ID
CVE-2022-44713	Microsoft Office: 2019 for Mac & Office LTSC for Mac: 2019	cpe:2.3:a:microsoft:microsoft_office:-:*:*:*:*:*	CWE-451
CVE-2022-41127	Dynamics NAV: 2016 – 2018 & Microsoft Dynamics 365 Business Central: 2019 Release Wave 2 On-Premise - 2022 Release Wave 2	cpe:2.3:a:microsoft:dynamics_nav:-:*:*:*:*:*	CWE-20
CVE-2022-44670	Windows: 7 - 11 22H2 & Windows Server: 2008 – 2022	cpe:2.3:o:microsoft:windows:-:*:*:*:*:* cpe:2.3:o:microsoft:windows_server:-:*:*:*:*:*	CWE-362
CVE-2022-44683	Windows: 8.1 - 11 22H2 & Windows Server: 2012 – 2022	cpe:2.3:o:microsoft:windows:-:*:*:*:*:* cpe:2.3:o:microsoft:windows_server:-:*:*:*:*:*	CWE-264

Recommendations



Security Leaders

Asset and vulnerability management solutions should be implemented to ensure that all internet-accessible devices are secure, patched, updated, hardened, and monitored. Integrate and communicate all lessons learned.



Security Engineers

- **Uni5 Users:** This is an actionable threat advisory in HivePro Uni5. Prioritize the vulnerability, identify the impacted assets, and patch them through your Command Center. Test your controls with Uni5's Breach & Attack Simulation.
- **All Engineers:** Refer to and action upon the 'Potential MITRE ATT&CK TTPs' & 'Patch Link' on the following pages.

Potential **MITRE ATT&CK** TTPs

<u>TA0001</u> Initial Access	<u>TA0003</u> Persistence	<u>TA0004</u> Privilege Escalation	<u>TA0008</u> Lateral Movement
<u>TA0043</u> Reconnaissance	<u>T1190</u> Exploit Public-Facing Application	<u>T1543</u> Create or Modify System Process	<u>T1547</u> Boot or Logon Autostart Execution
<u>T1574</u> Hijack Execution Flow	<u>T1548</u> Abuse Elevation Control Mechanism	<u>T1546</u> Event Triggered Execution	<u>T1068</u> Exploitation for Privilege Escalation
<u>T1210</u> Exploitation of Remote Services	<u>T1592</u> Gather Victim Host Information		

Patch Link

<https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2022-44698>

<https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2022-44710>

<https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2022-44690>

<https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2022-44693>

<https://msrc.microsoft.com/update-guide/vulnerability/CVE-2022-41089>

<https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2022-41076>

<https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2022-44678>

<https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2022-44681>

<https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2022-44713>

<https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2022-41127>

<https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2022-44670>

<https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2022-44683>

References

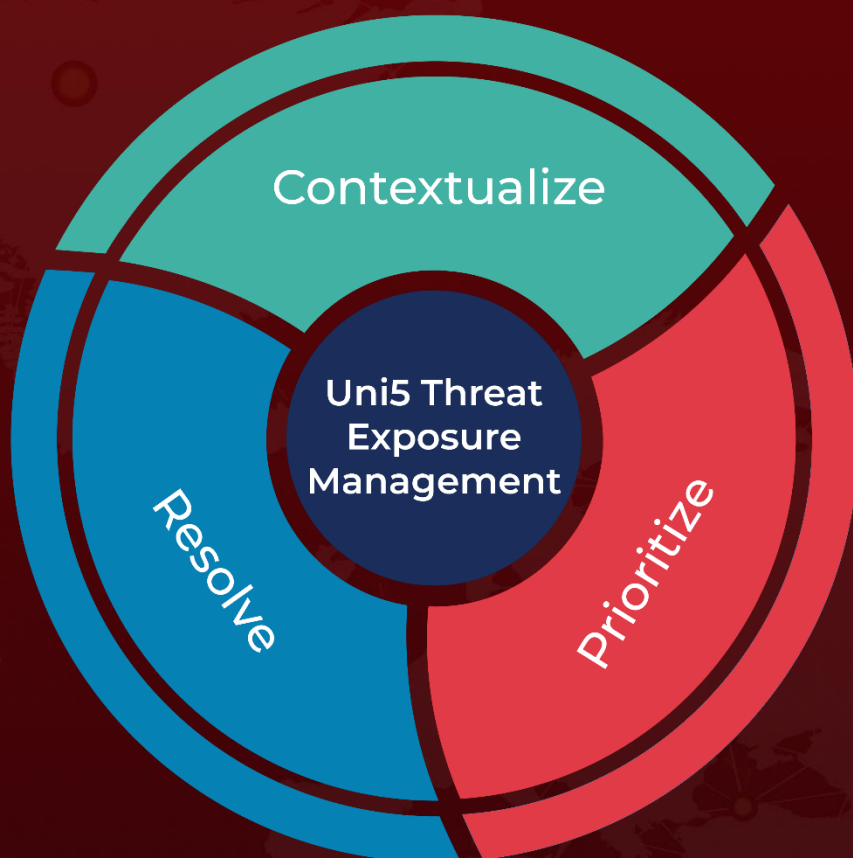
<https://msrc.microsoft.com/update-guide/releaseNote/2022-Dec>

<https://www.tenable.com/blog/microsofts-december-2022-patch-tuesday-addresses-48-cves-cve-2022-44698>

What Next?

At Hive Pro, it is our mission to detect the most likely threats to your organization and to help you prevent them from happening.

Book a free demo with HivePro Uni5: Threat Exposure Management Platform.



REPORT GENERATED ON

December 14, 2022 • 3:00 AM

© 2022 All Rights are Reserved by HivePro



More at www.hivepro.com